Documento de alcance · Fidelia

Grupo C · Seguridad en Entornos Móviles · Cierre del Bloque II

Fernando Sampalo Gómez · Pablo Anguita Pérez · Eric García Pedrosa · Pablo Rodríguez Gómez

1. La aplicación

Fidelia es una cartera de puntos de fidelización. El usuario entra con su cuenta, consulta su saldo de puntos y el historial de movimientos, escanea con la cámara los tiques de sus compras y canjea sus puntos por códigos de descuento.

La usaría cualquier cliente de un comercio con programa de puntos, desde su propio móvil.

El dato más delicado son los **códigos canjeables**, porque equivalen a dinero: quien consiga uno puede gastarlo sin ser el titular. Detrás van el token de sesión, que permite actuar como el usuario, y el historial de compras, que dice dónde y cuándo compra.

Estado actual (versión base, etiqueta `v1.0-bloque2`): acceso con usuario y contraseña, saldo de puntos, listado y detalle de movimientos, canje de puntos por códigos, copia local en Room, enlace profundo `fidelia://detalle/{id}` y escaneo de tiques con la cámara. Como el backend común no tiene saldo ni canje, se ha añadido `backend/servidor_fidelia.py`, que reutiliza el común sin modificarlo y le suma esas rutas; el servidor es quien comprueba el saldo y genera los códigos. Las fotos de los tiques todavía no suman puntos, porque no hay ruta para enviarlas. La aplicación es **insegura a propósito**: es el punto de partida del Bloque III.

2. Datos que maneja

Dato	Dónde se guarda hoy	Quién puede leerlo hoy	Cómo se protegerá
Token de sesión	`shared_prefs/sesion.xml`, en claro	Cualquiera con adb y depuración activada	Bloque III
Token de sesión	logcat (`Log.d` del repositorio e interceptor de red)	Cualquiera con adb; informes de errores	Bloque III
Usuario y contraseña	logcat (interceptor en nivel `BODY`) y tráfico HTTP sin cifrar	Cualquiera con adb; cualquiera en la misma red	Bloque III
Nombre de usuario	`sesion.xml` y columna `propietario` de la base de datos	Cualquiera con adb y depuración activada	Bloque III
Historial de movimientos	`databases/appbase.db` (y `-wal`), sin cifrar	Cualquiera con adb; copias de seguridad (`allowBackup="true"`)	Bloque III
Historial de movimientos	Tráfico HTTP sin cifrar	Cualquiera en la misma red	Bloque III
Fotos de los tiques	`files/tiques/*.jpg`, sin cifrar	Cualquiera con adb; copias de seguridad	Bloque III
Saldo de puntos	Tráfico HTTP sin cifrar (`/api/saldo`)	Cualquiera en la misma red	Bloque III
Códigos canjeables	Tabla `canjes` de `appbase.db`, sin cifrar	Cualquiera con adb; copias de seguridad. Quien los lea puede gastarlos	Bloque III
Códigos canjeables	Tráfico HTTP sin cifrar (`/api/canjes`)	Cualquiera en la misma red	Bloque III
Datos personales (DNI, correo)	Tráfico HTTP de `/api/perfil`	Cualquiera en la misma red	Bloque III

3. Superficie expuesta

Paquete `es.uma.seguridad.puntoseguro`.

Vía de entrada	Cómo se invoca hoy	Qué comprueba hoy	Se trata en
Activity principal exportada	`adb shell am start -n es.uma.seguridad.puntoseguro/.MainActivity`	Nada	Sesión 3.4
Enlace profundo `fidelia://detalle/{id}`	Enlace web, mensaje u otra aplicación	Nada en la interfaz; el repositorio exige token	Sesión 3.4

Vía de entrada	Cómo se invoca hoy	Qué comprueba hoy	Se trata en
Identificador del enlace	Cualquier número en la URL	Sólo que sea un entero; ni rango ni propietario	Sesión 3.4
Llamadas a la API	`curl` con un token válido	Sólo que haya token, no de quién es el dato	Sesión 3.5 · P3.2 · Bloque IV
Canje de puntos	`POST /api/canjes` con un token válido	Token y saldo suficiente (en el servidor); no hay límite de intentos ni confirmación	Sesión 3.5 · Bloque IV
Almacenamiento local (prefs, base de datos, tiques)	`adb shell run-as`	Nada: está en claro	Sesión 3.3 · P3.1
Copias de seguridad	`allowBackup="true"`	Nada	Sesión 3.3 · P3.1
Registros	`adb logcat`	Nada	Sesión 3.6
Vista de recientes y capturas	Botón del sistema	`FLAG_SECURE`	Sesión 3.6 · P3.3
Cámara	Botón «Escanear tique»	Permiso concedido por el usuario; la foto la hace la app de cámara del sistema	Sesión 3.4

4. Modelo de amenazas preliminar

1. **Alguien coge el móvil desbloqueado.** Un compañero de piso o quien encuentra el móvil abre Fidelia, ve el saldo y los movimientos, se apunta los códigos ya canjeados o canjea los puntos que queden y se los queda. Con un cable y la depuración activada puede además copiarse la base de datos y las fotos de los tiques sin abrir la aplicación.
2. **Alguien en la misma wifi.** En una cafetería o en la red de la universidad, otra persona ve pasar la contraseña y el token, porque todo va sin cifrar. Con el token entra como el usuario sin saber su contraseña.
3. **Otro cliente con su propia cuenta.** Un usuario normal cambia el número de la petición y obtiene los movimientos de otros clientes, porque el servidor no comprueba de quién es cada dato. Como los tokens son predecibles, también podría fabricar uno para otro usuario.
4. **Un enlace preparado.** Un mensaje o una página con un enlace `fidelia://detalle/…` abre la aplicación directamente en una pantalla concreta, sin que el usuario haya pasado por el inicio. Hoy no da acceso a datos sin sesión, pero es una puerta que cualquiera puede llamar.

5. Reparto de trabajo

Miembro	Requisito técnico mínimo	Qué cubre hoy
Fernando Sampalo Gómez	Autenticación	Inicio de sesión, token de sesión y cierre de sesión que borra los datos locales
Pablo Anguita Pérez	Almacenamiento local de datos sensibles	Copia local de movimientos y códigos en Room y fotos de tiques en el dispositivo
Eric García Pedrosa	API remota	Cliente Retrofit (acceso, movimientos, saldo y canje) y ampliación del backend `servidor_fidelia.py`
Pablo Rodríguez Gómez	Permiso peligroso	Cámara pedida en contexto para escanear tiques, con `uses-feature required="false"`